

GRC102 – Information Security Governance

Week 1 Practical Laboratory

Information Security Governance in Action

GlobalHealth Connect (GHC) — Executive Governance Simulation

Prepared

by

KHADIJA MUAZU KHALIL

C11/CGRCE/26/17559

Course: GRC102 – Information Security Governance

September 2026

EXECUTIVE SUMMARY

GlobalHealth Connect (GHC) has grown rapidly through product expansion and two acquisitions, and a recent contained data-leakage near-miss has exposed the limits of its ad-hoc approach to information security. This report responds to the Board's request for a structured, business-aligned information security governance function by delivering five governance artefacts:

- i. Task 1 – a governance blueprint establishing accountability through an organizational chart and a RACI matrix;
- ii. Task 2 – a formal Information Security Charter granting the programme mandate and authority;
- iii. Task 3 – a Board-level security metrics report translating technical data into business risk language;
- iv. Task 4 – a Security Steering Committee (SSC) design to resolve cross-functional security conflicts;
- v. Task 5 – a governance maturity assessment and a 12–18 month roadmap to reach Level 3 (Defined) maturity.

Together, these artefacts move GHC from a reactive, informally governed security function to a defined, accountable, and business-aligned governance model, consistent with recognized frameworks such as COBIT and ISO/IEC 27001.

TASK 1 — GOVERNANCE BLUEPRINT

1.1 Current-State Governance Gap Assessment

- a. No defined governance body or Board reporting line: Security is treated as a technical task performed within IT Operations (John Smith), with no CISO-equivalent role, no Board, and no executive visibility.
- b. Unclear accountability and ownership: No individual or committee is formally accountable for security outcomes; "security activities" are performed as a secondary duty rather than an owned responsibility.
- c. Absence of a formal, proactive risk management process: Risk is managed reactively, meaning risks are identified only after they materialize rather than being assessed and prioritized in advance.

- d. No cross-functional decision-making forum. Legal & Compliance, Finance, HR, Development and IT Operations currently operate in silos, with no structured mechanism to resolve competing priorities.
- e. No independent assurance function: There is no audit or compliance verification that controls are operating as intended.

1.2 Proposed Security Governance Organizational Chart

The proposed structure introduces a dedicated governance layer: a Director of Information Security Governance (CISO) — reporting operationally to the CEO for resourcing and sponsorship, with a functional (dotted-line) reporting relationship to the Board's Audit & Risk Committee to preserve independence when reporting on risk. A cross-functional Security Steering Committee (SSC), chaired by the CISO, brings together the CTO, CFO, Compliance, HR and IT Operations so that security decisions are made with full business context, addressing the silo weakness identified above.

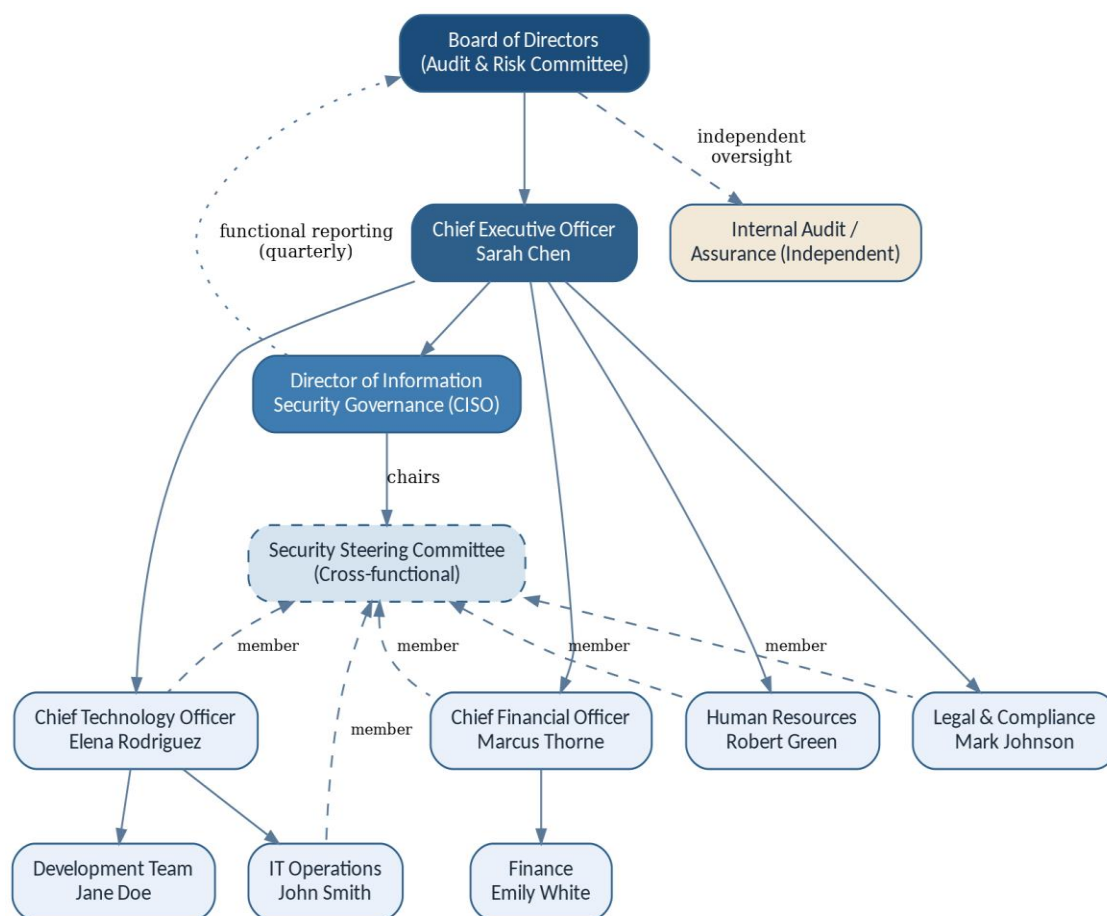


Figure 1. Proposed GHC information security governance structure.

1.3 RACI Matrix — Governance Activities

The matrix below assigns Responsible (R), Accountable (A), Consulted (C) and Informed (I) roles across eight core governance activities, closing the accountability gap identified in Section 1.1.

Governance Activity	Board	CEO	CISO	SSC	IT Mgr	Compliance Officer	Bus. Unit Leaders
Governance Charter approval	A	R	R (drafts)	C	I	C	I
Information security policy approval	I	A	R	C	C	C	I
Enterprise risk assessment & review	I	I	A/R	C	R	C	C
Incident response planning	I	I	A	C	R	C	R
Security budget approval	A	A	R	C	I	I	I
Security awareness training programme	I	I	A	I	C	R	R
Third-party / vendor risk review	I	I	A	C	C	R	C
Regulatory compliance reporting	C	A	R	I	I	R	I

1.4 How the Structure Supports Governance Principles

Accountability: Every governance activity now has a single Accountable owner (Board, CEO, or CISO), removing the ambiguity that previously left the near-miss without a clear owner.

Transparency: The CISO's functional reporting line to the Board Audit & Risk Committee, combined with an independent Internal Audit function, ensures risk information reaches the Board directly rather than being filtered solely through operational management.

Business alignment: The SSC gives Finance, Compliance, HR and Development a formal voice in security decisions, ensuring controls are shaped by business context rather than imposed unilaterally by IT.

Risk management: Assigning the CISO as Accountable for risk assessment (with IT Operations Responsible for execution) converts risk management from a reactive, informal activity into an owned, recurring governance process reviewed by the SSC.

Task 2 — GHC Information Security Charter.

2.1 Purpose

The GHC Information Security Programme exists to protect the confidentiality, integrity and availability of GHC's information assets, including patient data processed through GHC's cloud-based patient management systems so that GHC can pursue its strategic goals (market expansion, operational efficiency, customer trust, innovation and regulatory excellence) while managing information risk to a level acceptable to the Board.

2.2 Scope

This Charter applies to all information assets, applications, cloud infrastructure and physical/technical systems owned or operated by GHC and its acquired entities; all data processed by GHC, including patient health information and financial data; all employees, contractors and temporary staff; and all third parties and vendors with access to GHC systems or data.

2.3 Authority

The Information Security Programme derives its authority from the Board of Directors and the Chief Executive Officer. The Director of Information Security Governance (CISO) is authorized to: issue and mandate compliance with information security policies and standards; require remediation of identified control weaknesses within agreed timeframes; and escalate unresolved high or critical risks directly to the CEO and, where necessary, the Board Audit & Risk Committee, independent of business-unit management.

2.4 Roles and Responsibilities

- a. Board of Directors — sets organizational risk appetite, approves the Charter and major policies, and receives quarterly assurance reporting.

- b. Chief Executive Officer — sponsors the programme, allocates resources and is accountable for overall programme performance.
- c. CISO (Director of Information Security Governance) — leads strategy development, policy, risk management and day-to-day programme accountability.
- d. Security Steering Committee — provides cross-functional prioritization, review and conflict resolution.
- e. Business Unit Leaders — ensure security requirements are implemented and followed within their teams.
- f. Internal Audit / Compliance — independently verifies that controls are operating effectively.

2.5 Key Principles

- i. Risk-based — effort and investment are prioritized according to the risks that matter most to GHC and its patients.
- ii. Business-aligned — security decisions support, rather than obstruct, GHC's strategic goals.
- iii. Proportionate — controls are scaled to the sensitivity of the asset or data involved, avoiding unnecessary friction.
- iv. Continuously improving — the programme is reviewed and matured over time rather than treated as a one-off project, consistent with ISO/IEC 27001's continual improvement requirement.

2.6 Reporting Structure

The CISO reports operationally to the CEO on programme delivery and resourcing, and functionally to the Board Audit & Risk Committee on a quarterly basis for independent risk oversight. The Security Steering Committee meets monthly and reports outcomes to the CISO. Business Unit Leaders escalate cross-functional security matters to the SSC.

2.7 Review and Approval

This Charter is approved by the Chief Executive Officer and ratified by the Board of Directors. It will be formally reviewed annually and upon any material organizational change (including further acquisitions), with version history and change rationale maintained by the CISO.

2.8 Justification Memo to Marcus Thorne, CFO

Memorandum

To: Marcus Thorne, Chief Financial Officer

From: Director of Information Security Governance

Re: Information Security Charter — Investment Justification

The attached Charter formalizes accountability for information security spending by assigning a single Accountable owner (the CISO) to each governance activity, replacing today's undocumented, ad-hoc allocation of effort. This directly supports GHC's strategic goal of Enhancing Operational Efficiency: budget requests will now be tied to specific, risk-prioritized initiatives rather than reactive fixes, allowing Finance to evaluate security spend on a cost-avoidance and return-on-investment basis rather than as an unplanned overhead.

More significantly, the Charter is a precondition for protecting the Maintain Customer Trust and Achieve Regulatory Excellence goals that underpin GHC's revenue: as a healthcare technology provider, a major data breach or regulatory finding would jeopardize the client relationships that the Expand Market Share goal depends on. Formal governance — with Board-level oversight and independent assurance — is the most cost-effective way to demonstrate to regulators, auditors and prospective clients that patient data is being protected proactively, rather than paying for remediation and reputational recovery after an incident.

TASK 3 — BOARD REPORTING AND SECURITY METRICS

3.1 Board Executive Summary

Overall Security Posture: RED

Over the past six months, high-risk security incidents have more than tripled (2 to 7 per month) while the percentage of critical vulnerabilities patched has declined from 67% to 55%; the two most business-relevant indicators are moving in the wrong direction simultaneously. Phishing attempts have more than doubled, indicating GHC is an increasingly active target, consistent with its growth and higher public profile following two acquisitions. The one clearly positive trend is security awareness training completion, which has risen steadily from 45% to 70%. On balance, the deteriorating patching performance combined with the sustained rise in high-risk incidents represents a material and worsening

risk to patient data and service availability, warranting a RED rating and immediate Board attention, notwithstanding the encouraging training trend.

3.2 Selected Metrics — Six-Month Trend

Metric	Sep	Feb (current)	6-Month Trend	Board Commentary
High-Risk Incidents	2	7	Rising	Most urgent Board concern; rising incidents indicate increasing realized risk.
Critical Vulnerability Patching	67%	55%	Declining	Deteriorating treatment of critical weaknesses increases operational and data risk
Phishing Attempts	150	320	Rising	Increasing threat exposure; requires continued awareness and preventive controls.
Malware Events	25	50	Rising	Threat activity has doubled; indicates need for stronger prevention, detection and response.
Security Awareness Training Completion	45%	70%	Improving	Positive progress, but 30% remains incomplete; engagement needs further improvement..

3.3 Priority Risks and Recommendations

Increasing phishing attempts: Strengthen awareness and deploy enhanced technical anti-phishing controls.

Widening exposure from unpatched critical vulnerabilities: Set a Board-approved target for critical vulnerability treatment and require escalation for overdue critical items.

3.4 Rationale for Metric Selection

The five metrics were selected because they:

- i. Translate technical activity into business and patient-safety risk rather than raw technical counts.
- ii. Provide six months of trend visibility, allowing the Board to see direction rather than a single point-in-time snapshot.
- iii. Balance a leading indicator against lagging indicators (incidents, patching).
- iv. They are directly material to GHC's "Maintain Customer Trust" strategic goal, which depends on protecting patient information from the vulnerabilities and threats these metrics track. Task 4 — Security Steering Committee

4.1 Security Steering Committee — Terms of Reference

Purpose

The Security Steering Committee (SSC) provides cross-functional strategic direction, prioritization and conflict resolution for GHC's information security programme, ensuring decisions reflect business, technical and compliance perspectives rather than being made unilaterally by a single function.

Scope

- i. Review and recommend information security policies and standards before executive approval.
- ii. Review the enterprise risk register and monitor treatment progress.
- iii. Resolve cross-functional conflicts between security requirements and business/technical priorities (e.g., the password policy dispute below).
- iv. Oversee security programme initiatives, budget recommendations and post-incident reviews.

Membership

- i. Chair: Director of Information Security Governance (CISO)
- ii. Members: Chief Technology Officer; Chief Financial Officer (or delegate); Compliance Officer; HR Manager; IT Manager; a rotating Business Unit representative (e.g., Senior Developer)
- iii. Secretary: administrative support for minutes and action tracking

Responsibilities

- i. Endorse policies and operational standards prior to CEO/Board approval where required.
- ii. Resolve cross-functional disagreements by consensus, escalating unresolved strategic issues to the CEO.

- iii. Monitor key risk indicators and sponsor remediation of priority risks.
- iv. Champion security awareness and cultural change across business units.

Meeting Cadence

The SSC meets monthly. Urgent cross-functional conflicts (such as the password policy dispute) are convened within five business days of being raised to the Chair.

Decision Authority

The SSC has authority to approve operational security standards and procedures below Charter/policy level. Decisions are made by consensus; where consensus cannot be reached, the CISO makes the final operational decision, with either the CISO or a dissenting member able to escalate to the CEO for matters affecting risk appetite or major cost.

Reporting

Meeting minutes and actions are circulated within five business days. A quarterly SSC summary report is provided to the CEO and the Board Audit & Risk Committee.

4.2 Sample Agenda — First SSC Meeting

Item	Topic	Lead	Time
1	Welcome, introductions and purpose of the SSC	CISO (Chair)	10 min
2	Review and formal adoption of the Terms of Reference	CISO	10 min
3	Overview of the GHC governance blueprint and Charter	CISO	15 min
4	Key discussion: Password policy conflict — 16-character/30-day complex password proposal vs. MFA + password-manager approach	CTO / IT Manager	30 min
5	Review of open risk items and near-miss follow-up actions	CISO	15 min

Item	Topic	Lead	Time
6	Any other business and confirmation of next meeting date	Chair	10 min

4.3 Briefing Note to the CEO

To: Sarah Chen, Chief Executive Officer

From: Director of Information Security Governance

Subject: Establishment of the Security Steering Committee

The proposed Security Steering Committee will provide GHC with a formal cross-functional mechanism for resolving security issues that affect more than one business function. The current password-policy dispute illustrates why this is necessary: the IT Manager is focused on stronger controls, while the CTO is concerned about operational friction. Rather than allowing either function to decide independently, the SSC will evaluate risk, business impact, alternatives and resource implications before recommending a proportionate decision.

The SSC will also strengthen strategic alignment by bringing technology, compliance, finance, HR and business perspectives into security decisions. It will review security risks and metrics, prioritise initiatives, monitor the governance roadmap and escalate material matters to you and the Board. This creates a transparent decision trail and supports the governance principle that leadership sets direction and oversight while management implements approved requirements.

TASK 5 — GOVERNANCE MATURITY ASSESSMENT

5.1 Current-State Maturity Assessment

Governance Domain	Current Level	Evidence / Rationale
Policy & Documentation	Level 2 – Initial	Policies exist but are inconsistent, inherited from acquisitions, and not consistently kept current — some documentation exists but is not standardized or reliably applied.

Governance Domain	Current Level	Evidence / Rationale
Roles & Responsibilities	Level 1 – Ad Hoc	Security ownership and accountability are unclear; no formally defined roles exist prior to this governance blueprint.
Risk Management	Level 1 – Ad Hoc	The organisation is reactive, addressing risks only as problems arise, with no formal proactive assessment process.
Metrics & Reporting	Level 2 – Initial	Technical metrics are collected, but they are not consistently translated into business-relevant reporting for decision-makers.
Training & Awareness	Level 2 – Initial	Annual training is mandatory (a defined process exists), but engagement/completion is low, indicating inconsistent effectiveness.
Compliance	Level 2 – Initial	Compliance preparation is audit-driven rather than continuously monitored, i.e., activity exists but is not embedded as an ongoing process.

5.2 12–18 Month Maturity Roadmap

Initiative	Timeline	Objective	Key Activities	Measurable Expected Outcome
Initiative 1: Establish Governance Structure & Charter	Months 1–3	Formalize accountability for information security across GHC.	Approve the Information Security Charter; appoint the CISO; establish and launch the Security Steering Committee; publish the RACI matrix organization-wide.	100% of governance roles documented, communicated and acknowledged; Roles & Responsibilities reaches Level 3.
Initiative 2: Policy	Months 1–6	Replace inconsistent,	Inventory existing policies from both acquisitions; gap-	A single, Board-approved policy suite

Initiative	Timeline	Objective	Key Activities	Measurable Expected Outcome
Harmonization Programme		inherited policies with a single, current policy suite.	assess against ISO/IEC 27001 Annex A control domains; consolidate into one approved GHC policy set; deliver policy-awareness training to all staff.	covering all required domains, reviewed on a defined annual cycle; Policy & Documentation reaches Level 3.
Initiative 3: Formal Risk Management Programme	Months 2–8	Shift risk management from reactive to proactive and structured.	Implement a formal risk register; conduct an enterprise-wide risk assessment; agree risk appetite with the Board; establish quarterly risk review via the SSC.	Documented risk register covering all critical systems, with a standing quarterly review cadence; Risk Management reaches Level 3.
Initiative 4: Business-Aligned Metrics & Reporting	Months 3–9	Translate technical security data into consistent, business-relevant Board reporting.	Define a standing set of Board-level KPIs/KRIs (building on Task 3); build a quarterly Board security dashboard; automate data collection from existing tools where feasible.	A quarterly Board security report adopted as standing practice and reviewed at every Board cycle; Metrics & Reporting reaches Level 3.
Initiative 5: Training & Culture Uplift	Months 1–12	Move beyond compliance-only annual training to sustained engagement.	Introduce role-based phishing simulations and quarterly micro-learning; tie completion and phishing-simulation performance into team-level reporting.	Training completion sustained at 90%+ and phishing simulation click-rate reduced by a measurable, targeted amount within 12 months; Training &

Initiative	Timeline	Objective	Key Activities	Measurable Expected Outcome
				Awareness reaches Level 3.

5.3 Executive Summary to the Board

GHC's information security governance is currently assessed at Level 1 to Level 2 (Ad Hoc/Initial) across all six domains, reflecting the historical absence of a dedicated governance function and the inconsistency introduced by two acquisitions. This is not unusual for an organization at GHC's stage of growth, but it is no longer proportionate to GHC's risk profile as a handler of sensitive patient data.

The proposed 12–18 month roadmap, delivered through five prioritized initiatives, is designed to bring every domain to Level 3: documented, standardized and clearly owned. This is strategically important for three reasons: it directly reduces the risk of a patient-data breach that would undermine the Maintain Customer Trust and Achieve Regulatory Excellence goals; it gives the Board reliable, business-relevant visibility of security performance for the first time; and it establishes a governance foundation capable of scaling safely as GHC pursues further market expansion and acquisitions.

REFERENCES

COBIT 2019 Framework: Introduction and Methodology. ISACA.

ISO/IEC 27001:2022 — Information security, cybersecurity and privacy protection — Information security management systems — Requirements. International Organization for Standardization.

National Institute of Standards and Technology (NIST). (2017). SP 800-63B: Digital Identity Guidelines — Authentication and Lifecycle Management.